

SOC CAPSTONE INVESTIGATION — CASE 003

Classification: CONFIDENTIAL

Difficulty: Advanced

Background briefing:

You are a SOC analyst at a financial services company called FinanceCore Ltd. It is a Monday morning. Your SIEM has flagged unusual activity over the weekend when minimal staff were present. Your manager has asked you to investigate and produce a full report before the afternoon briefing.

INCIDENT REPORT

2. Incident overview

On the 15th of June 2024, a multistage security incident compromised Host PC FINCORE-WS04 and Mthembu user account. The attack involved several MITRE Att&ck techniques covered below. The breach began with automated malware beaconing to a fake domain, the attacker later brute-forced the local user account Mthembu to gain full administrative privileges. Once inside, they disabled the antivirus, accessed local files and exfiltrated 128MB of data.

3. Timeline of events

00:03:11 DNS_QUERY host=FINCORE-WS04 query=updates.microsofft.com

00:03:45 DNS_QUERY host=FINCORE-WS04 query=updates.microsofft.com

00:04:19 DNS_QUERY host=FINCORE-WS04 query=updates.microsofft.com

00:04:53 DNS_QUERY host=FINCORE-WS04 query=updates.microsofft.com

00:05:27 DNS_QUERY host=FINCORE-WS04 query=updates.microsofft.com

00:06:01 DNS_QUERY host=FINCORE-WS04 query=updates.microsofft.com

00:14:22 FAILED_LOGIN user=mthembu src_ip=41.185.28.93 status=FAILED

00:14:25 FAILED_LOGIN user=mthembu src_ip=41.185.28.93 status=FAILED

00:14:28 FAILED_LOGIN user=mthembu src_ip=41.185.28.93 status=FAILED

00:14:31 FAILED_LOGIN user=mthembu src_ip=41.185.28.93 status=FAILED

00:14:34 FAILED_LOGIN user=mthembu src_ip=41.185.28.93 status=FAILED
00:14:37 SUCCESS_LOGIN user=mthembu src_ip=41.185.28.93
00:15:03 FILE_ACCESS file=C:\FinanceCore\clients\accounts_2024.xlsx
00:15:44 FILE_ACCESS file=C:\FinanceCore\clients\transactions_q2.xlsx
00:16:02 FILE_ACCESS file=C:\FinanceCore\internal\staff_salaries.xlsx
00:16:55 ARCHIVE_CREATED file=C:\temp\data_backup.zip size=128MB
00:17:33 ANTIVIRUS_DISABLED user=mthembu
00:18:01 OUTBOUND_CONNECTION dst_ip=196.203.44.81 port=443
00:19:22 NEW_USER_CREATED user=svc_update01 privileges=ADMIN
00:21:05 SCHEDULED_TASK_CREATED task=WindowsUpdateHelper
00:22:44 SUCCESS_LOGIN user=svc_update01 src_ip=196.203.44.81
00:23:10 OUTBOUND_CONNECTION dst_ip=196.203.44.81 port=4444
00:24:01 REGISTRY_MODIFIED
00:31:17 SUCCESS_LOGIN user=svc_update01
00:31:44 FILE_ACCESS file=C:\FinanceCore\internal\network_diagram.pdf
00:32:09 FILE_ACCESS file=C:\FinanceCore\internal\admin_credentials.txt
00:33:55 OUTBOUND_CONNECTION dst_ip=196.203.44.81 port=4444

4. Attack phases Identified

There are several MITRE ATT&CK techniques used in this incident, which include the following:

Initial compromise

Based on the log the host PC was sending DNS queries to find the IP of the fake Microsoft domain which is misspelled ://microso^{ft}.com, this is a form of malicious typosquatting. This suggests that the PC already had malware running in it hence it was able to send DNS query, therefore indicating initial compromise.

Command and Control

The host IP was sending DNS queries which suggests it was being fed malware by a possible Command and control C2 server, even without access.

Initial access

There were 5 failed login attempts followed by a successful login into a user account indicating initial access.

Defense evasion

The attacker was attempting defense evasion by disabling the antivirus to reduce detection and prevention.

Persistence

The unauthorized scheduled task may provide persistence, allowing the attacker to execute malicious activity again at a later stage.

Exfiltration

Based on the log when outbound connection was established it had the same file size as the file archive created, suggesting that the file was transferred during the outbound connection.

5. IOCs Identified

There are several IoC identified in this incident which include the following:

5 failed login attempts.

Successful login to Mthembu user account and user=svc_update01

Command and control C2 server to microsfst.com

Beaconing

File archive was created data_backup.zip

Antivirus was disabled.

New user was created user=svc_update01 (admin privilege)

Outbound connection established to ip=196.203.44.81

Registry was modified.

128MB file during outbound connection to ip=196.203.44.81

6. Containment Recommendations

The infected host PC FINCORE-WS04 should be disconnected from the internet to stop connection to ip=196.203.44.81 and communication to the command-and-control C2 server.

The affected user accounts Mthembu and svc_update01 should be temporarily disabled, so that they can't be used to access more files.

The firewall should block both outbound and inbound traffic to the external Ip 196.203.44.81, preventing the host Ip from sending traffic to it.

8. Long term recommendations

To prevent similar incidents and harden the environment, implement the following security controls:

Deploy Endpoint Detection and Response (EDR) agents to detect and automatically block malicious persistence mechanisms like unauthorized scheduled tasks.

Enforce Multi-Factor Authentication (MFA) across all local and domain user accounts to neutralize credential brute-force attacks.

Implement robust account lockout policies to automatically freeze accounts after a small number of consecutive failed login attempts.

Configure DNS filtering security controls to detect and block connections to newly registered or known typosquatted domains.

Establish a centralized patch management schedule to ensure operating systems and security defenses remain fully up to date

9. Lessons Learned

An analysis of this incident highlights critical vulnerabilities in existing security monitoring and access controls:

Delayed Visibility: The significant gap between the initial malware beaconing (03:03:11) and the brute-force attack (14:14:28) indicates a lack of real-time alerting for high-risk DNS queries.

Weak Authentication Controls: The success of the brute-force attack shows that local administrative accounts lacked multi-factor authentication (MFA) and basic lockout policies.

Inadequate Endpoint Defense: Local security controls failed to protect core services, allowing the attacker to easily disable local antivirus defenses on FINCORE-WS04.

Lack of Egress Filtering: The outbound network architecture permitted a massive 128MB data transfer to an unverified external IP without triggering automated data loss prevention blocks

10. Conclusion — final severity rating and escalation decision

Due to confirmed administrative credential theft, local defense evasion, and the successful exfiltration of 128MB of sensitive data, this incident is classified as a Critical-Severity (Tier 3) event requiring immediate escalation to the Chief Information Security Officer (CISO) and the Cyber Security Incident Response Team (CSIRT). This decision mandates the immediate network isolation of host FINCORE-WS04, a company-wide threat hunt using the identified network indicators of compromise (IoCs).